

2026-07-01-real-account-code-server-design

Real-account-tied code-server — design spec

Revision: 1 **Last modified:** 2026-07-01T00:00:00Z **Status:** approved (design forks + design approved by operator 2026-07-01) **Authority:** operator mandate 2026-07-01 (this session) **Scope:** HelixCode deploy — auth + runtime model + editor jail

1. Goal

Every code-server session is tied to a **real host user account** (default milosvasic) so it has that user's full capability:

- **All SSH keys** already registered with our Git services (host ~/.ssh) work for git over SSH from the editor terminal.
- **Everything from .bashrc** (exported vars + init steps) works in a fresh terminal session.
- **All system apps / binaries / utils** the user normally has are available.
- The **login screen authenticates against the real account password via PAM, live** — nothing stored anywhere (no password in repo, config, env, logs, or evidence).
- The editor **file navigation is scoped to the projects directory** (user can't browse outside it in the explorer), while the **terminal keeps full real-user capability** (SSH, all binaries).

2. Approved architecture (operator, 2026-07-01)

Browser —HTTPS :52443→ Caddy (TLS edge, containerized \$11.4.76, unchanged TLS modes)

└─ forward_auth → helix-pam-auth

```

(127.0.0.1:<p>, host-native)
|
entered pw for HELIX_AUTH_ACCOUNT | POST /login : PAM-verify
|
check (valid cookie→200 else 401) | GET /auth : forward-auth
|
POST /logout : clear cookie | GET /login : login page ;
|
| cookie: signed (HMAC)
HttpOnly Secure SameSite=Lax, TTL+sliding
|
| NOTHING stored ; password
never logged/persisted
└ reverse_proxy → code-server

(127.0.0.1:8080, --auth none)
systemd --user service AS
milosvasic (linger already enabled)
inherits ~/.ssh, ~/.bashrc,
ALL host binaries natively
opens $PROJECTS_ROOT as
workspace (editor file-tree jail)
integrated terminal = login
shell → full real-user capability

```

Runtime model = **host-native as the real user** (chosen over containerized keep-id+bind — the only clean way to give “all host binaries the user usually has”). Caddy edge stays containerized per §11.4.76; only the editor + auth processes are host-native (a legitimate non-containerized case — they fundamentally require the host’s real identity + toolchain + PAM).

3. Components

3.1 helix-pam-auth (new Go static binary)

- Path: services/pam_auth/ (Go module; decoupled, project-agnostic §11.4.28).
- Endpoints: GET /auth, GET /login, POST /login, POST /logout, GET /healthz.
- PAM: verify HELIX_AUTH_ACCOUNT’s password via pam_authenticate (service file /etc/pam.d/helix-pam-auth → pam_unix/system-auth).
- **Privilege (load-bearing, spike first): runs as milosvasic** (systemd --user). pam_unix verifies via the setuid-root helper unix_chkpwd, which permits a **non-root caller to check its OWN user’s password** — so no root daemon is needed. **Task P0 proves this on the host** before the full build (§11.4.150). Fallback if disproven: a system service running as a dedicated user in the shadow group, OR a minimal setuid check helper — chosen only on captured evidence, documented per §11.4.112 if a hard limit is hit.
- Security: loopback-only bind; login **rate-limited** (anti-brute-force, fail-closed); cookie HMAC secret generated to a 0600 file

(regenerated if absent); password bytes never written to disk/
logs (zeroed after use); constant-time compares;
HttpOnly+Secure+SameSite cookie; session TTL.

- **FAIL CLOSED:** any auth-service error/outage ⇒ Caddy denies (never proxies to code-server). The #1 security invariant — tested by stress/chaos.

3.2 code-server host-native

- `systemd --user` unit for milosvasic: `code-server --auth none --bind-addr 127.0.0.1:8080 --user-data-dir <dir> $PROJECTS_ROOT`.
- Runs as milosvasic ⇒ `~/.ssh`, `~/.bashrc`, all host binaries native.
- Opens `$PROJECTS_ROOT` as the workspace ⇒ explorer scoped there (editor jail).
- Terminal spawns a login shell (`bash -l`) ⇒ `.bashrc`/profile sourced, full capability by design.
- Install path resolves the code-server binary (npm global / standalone / existing container image extraction) — determined in Task P0.

3.3 Caddy

- `up.sh` Caddyfile render gains: `forward_auth` to `helix-pam-auth` for the app, `serve /login + static assets`, `reverse_proxy` to host-native code-server (host.containers.internal or the host gateway IP from the rootless netns).
- TLS modes (self-signed / letsencrypt* / internal-acme) preserved from 0.0.0.2.

4. Parameters (replace CODE_SERVER_PASSWORD)

- `HELIX_AUTH_MODE=pam` (only mode this release).
- `HELIX_AUTH_ACCOUNT=milosvasic` (the system account sessions tie to).
- `PROJECTS_ROOT` / existing `PROJECTS` (workspace + jail root).
- **No password parameter.** Entered live at login, PAM-verified, stored nowhere.
- `.env.example` updated (placeholders only); `CODE_SERVER_PASSWORD` retired.

5. Test-time secret handling (§11.4.10 / §11.4.10.A / §11.4.98)

Production stores nothing. Autonomous integration/e2e (§11.4.98, no manual step) needs the real password to prove *correct→success*: - Lives ONLY in git-ignored scripts/testing/

secrets/host_account.env (0600), keys HELIX_TEST_ACCOUNT, HELIX_TEST_PASSWORD. - **§11.4.10.A pre-store audit:** repo tree + full history scanned for prior leaks of the value (counts/paths only, value never echoed) BEFORE storing. - .gitignore covers scripts/testing/secrets/ (verify/add). - Never committed, never logged; evidence records the OUTCOME (“correct pw → 200 + cookie”), never the value.

6. Test coverage — full §11.4.169, real evidence (anti-bluff)

- **unit** (mocks allowed here only): cookie HMAC sign/verify, TTL+sliding, rate-limit state machine, config parse, PAM wrapper seam.
- **integration:** real helix-pam-auth + real PAM stack → correct pw → 200 + cookie ; wrong pw → 401, no cookie ; code-server reachable ONLY via the gate.
- **e2e:** login journey via Caddy (unauth→login ; correct account pw→editor ; wrong→denied) + terminal-as-milosvasic **SSH-key git action succeeds** (git ls-remote git@github.com:vasic-digital/Code-Server.git) + a .bashrc export present in a fresh terminal + workspace scoped to \$PROJECTS_ROOT.
- **full_automation:** N=3 deterministic, self-driving (§11.4.50/§11.4.98).
- **security:** no plaintext password anywhere (tree scan, value not echoed); cookie HttpOnly+Secure+SameSite ; login rate-limited ; TLS enforced ; PAM service least-privilege ; ~/.ssh perms sane / not leaked.
- **load / DDoS:** login endpoint flood → rate-limit holds, no crash.
- **stress_chaos:** kill helix-pam-auth → **auth FAILS CLOSED** (Caddy denies, never bypasses) ; kill code-server → recovers ; corrupt cookie secret → sessions invalidated, not bypassed ; fd/oom pressure.
- **concurrency / race:** concurrent logins, atomic cookie issuance, no session fixation, no deadlock.
- **memory / benchmark:** helix-pam-auth RSS bounded ; login p50/p95/p99 vs baseline.
- **challenges + helixqa:** capability challenges — real-account login, SSH-key push, .bashrc var, editor jail — PASS only on captured evidence.
- Each fix ships §11.4.115 RED→GREEN polarity + §11.4.135 regression guard; each suite has a paired §1.1 mutation.

7. Docs (extend all existing)

README (auth/quick-start rewrite), new docs/guides/AUTH.md (real-account model, PAM, SSH keys, jail, operator prerequisites), docs/guides/TLS.md xref, docs/features/Status.md new rows, docs/qa/<run-

id>/ curated evidence, changelog docs/changelogs/
codeserver-1.0.0-dev-0.0.3.md. HTML/PDF export is a known pre-existing project gap (not introduced here).

8. Migration / rollback

- New: services/pam_auth/, systemd units (code-server + pam-auth as milosvasic), Caddyfile forward_auth render, install.sh wiring, .env.example.
- Retire container code-server service + CODE_SERVER_PASSWORD; Caddy + TLS machinery unchanged. Reversible (git revert + prior release tag).

9. Live validation + release

Install on THIS host, bring the stack up, run the full §11.4.169 matrix live (§11.4.40), capture evidence, independent code review to GO (§11.4.142/§11.4.134), then release codeserver-1.0.0-dev-0.0.3 (VERSION + changelog + tag on all 4 mirrors + GitHub/GitLab releases). Built subagent-driven (§11.4.70).

10. Key risks / open technical items (resolve early, evidence-first §11.4.6)

- **P0 spike:** PAM-as-milosvasic via unix_chkpwd for own-user verify — prove on host before full build; pick privilege model on evidence.
- code-server host binary source (npm global vs standalone tarball vs extract from image) — resolve in P0.
- rootless-podman Caddy → host-native code-server/pam-auth reachability (host gateway IP / host.containers.internal / host network) — resolve in P0.
- Non-negotiable security invariant: **auth fails CLOSED**.